Registre de traitement — Lidl Collect (Art. 30 RGPD)

> Responsable de traitement : Équipe projet — Lidl Collect (projet académique ; responsable fictif) DPO : Non désigné (projet scolaire — prototype). En contexte réel, Lidl SAS étant soumise à l'article 37, paragraphe 1, point b) du RGPD (traitement à grande échelle), la désignation d'un délégué à la protection des données serait obligatoire. Base de données : PostgreSQL via Supabase — région Frankfurt (Union européenne) — aucun transfert hors de l'Union européenne Dernière mise à jour : 2026-04-16 Référence légale : Art. 30 RGPD — Registre des activités de traitement

SOMMAIRE DES ACTIVITÉS DE TRAITEMENT

#	ACTIVITÉ	TABLES CONCERNÉES	BASE LÉGALE PRINCIPALE
T01	Création et gestion du compte client	`Client`, `Client_Account`	Exécution du contrat
T02	Authentification et gestion des sessions	`Client`, `Client_Account`, JWT	Exécution du contrat
T03	Gestion des commandes	`Order`, `OrderItem`, `Payment`	Exécution du contrat
T04	Gestion du panier	`Cart`, `CartItem`	Exécution du contrat
T05	Programme de fidélité	`Client_History`	Intérêt légitime
T06	Notifications transactionnelles	`Notification`	Exécution du contrat
T07	Gestion du consentement cookies	`Consent`	Obligation légale (preuve)
T08	Journalisation des actions système	`AuditLog`	Intérêt légitime
T09	Gestion des employés — Préparateurs	`Preparer`	Exécution du contrat de travail
T10	Gestion des Managers	`Manager`	Exécution du contrat de travail
T11	Gestion des plannings	`Schedule`	Exécution du contrat de travail
T12	Suivi des performances Préparateurs	`Performance`	Intérêt légitime employeur
T13	Logs serveur Nginx	Logs fichiers	Intérêt légitime (sécurité)
T14	Substitutions de produits	`SubstitutionProposal`	Exécution du contrat
T15	Gestion des créneaux de retrait	`PickupSlot`	Exécution du contrat

T01 — CRÉATION ET GESTION DU COMPTE CLIENT

CHAMP	VALEUR
Données traitées	Nom, prénom, email, mot de passe (Bcrypt), téléphone, adresse postale, magasin préféré (FK), statut de vérification email (`is_verified`), statut du compte (`is_active`), date de création, date de dernière connexion
Tables	`Client` , `Client_Account`
Finalité	Créer et gérer l'identité numérique du client sur l'application. Permettre l'authentification, la personnalisation du service et le suivi des commandes.
Base légale	**Art. 6.1.b — Exécution du contrat** : le compte est la condition sine qua non d'accès au service. Sans identité vérifiée, aucune commande ne peut être passée ni retirée.
Justification	Toutes les données collectées sont strictement nécessaires à l'exécution du service : l'email pour la communication et le double opt-in, le téléphone pour les notifications critiques, l'adresse pour le profil de livraison potentiel, le mot de passe pour l'authentification sécurisée.
Restriction d'âge	Service réservé aux **majeurs (18+)**. Déclaration sur l'honneur à l'inscription ("Je certifie avoir 18 ans ou plus"). Pour les produits réglementés (alcool), la vérification effective repose sur le contrôle visuel de l'employé Lidl au retrait — exactement comme en caisse physique. Art. L.3512-3 CSP : la vente de tabac en ligne étant interdite en France, aucun produit tabac ne doit figurer dans le catalogue.
Durée de conservation	Durée d'activité du compte. **2 ans d'inactivité** → notification email → 30 jours délai de réactivation → pseudonymisation/suppression physique.
Acteurs ayant accès	CLIENT (ses propres données) / ADMIN (toutes les données) / Système (vérification automatisée)
Transfert hors UE	Non — Supabase Frankfurt (EU)
Mesures de sécurité	Mot de passe haché Bcrypt. Email vérifié par double opt-in (`is_verified`). Les données d'authentification sont exclues de toutes les réponses API. Chiffrement au repos AES-256 (Supabase). Transport TLS.

T02 — AUTHENTIFICATION ET GESTION DES SESSIONS

CHAMP	VALEUR
Données traitées	Email (identifiant), mot de passe (Bcrypt — jamais en clair), JWT access token (payload : `userId`, `role`, `storeId`), JWT refresh token, adresse IP (logs), `last_login_at`
Tables	`Client` (lecture), `Client_Account` (mise à jour `last_login_at`), logs Nginx/NestJS
Finalité	Vérifier l'identité de l'utilisateur à chaque requête. Maintenir une session sécurisée avec expiration automatique. Détecter les tentatives d'accès non autorisées.
Base légale	**Art. 6.1.b — Exécution du contrat** : l'authentification est la condition d'accès au service contractuel.
Durée de conservation	JWT access token : 15 min (CLIENT/OPERATOR/MANAGER), 10 min (ADMIN). JWT refresh token : 7 jours (CLIENT), 8h (OPERATOR/MANAGER), 4h (ADMIN). `last_login_at` : durée du compte actif.
Acteurs ayant accès	CLIENT (son propre token) / ADMIN (logs d'audit) / Système (validation automatique)
Transfert hors UE	Non
Mesures de sécurité	MFA obligatoire pour OPERATOR, MANAGER, ADMIN. Rejet explicite de `alg: none` dans NestJS. Payload JWT sans donnée personnelle. Adresses IP conservées 1 an (Art. L34-1).

T03 — GESTION DES COMMANDES

CHAMP	VALEUR
Données traitées	`client_id` (FK), `store_id`, `pickup_slot_id`, `preparer_id` (nullable), statut commande, montant total, code de retrait, articles commandés (quantité, prix unitaire au moment de la commande), propositions de substitution
Tables	`Order`, `OrderItem`, `SubstitutionProposal`, `Payment`
Finalité	Permettre au client de commander des produits et de les récupérer en magasin. Permettre aux préparateurs de traiter les commandes. Conserver la trace comptable légale.
Base légale	**Art. 6.1.b — Exécution du contrat** pour le traitement actif. **Art. 6.1.c — Obligation légale** pour la conservation post-effacement (Art. L123-22 Code de commerce — 10 ans).
Durée de conservation	Active : durée du compte client. Après effacement du compte : **pseudonymisation du** `client_id` (HMAC-SHA256), conservation 10 ans (obligation comptable).
Acteurs ayant accès	CLIENT (ses propres commandes) / OPERATOR (commandes de son magasin) / MANAGER (commandes de son magasin) / ADMIN (toutes)
Transfert hors UE	Non
Mesures de sécurité	Contrainte `storeId` côté backend (OPERATOR/MANAGER ne voient que leur magasin). Guard IDOR : `order.clientId === req.user.id`. Code de retrait : généré côté serveur, usage unique.
Note paiement	Dans la version actuelle du système, les modes de paiement implémentés sont `IN_STORE` et `SIMULATED_ONLINE`. Aucune donnée bancaire réelle ne transite dans le système.

T04 — GESTION DU PANIER

CHAMP	VALEUR
Données traitées	`client_id` (FK), `store_id`, statut du panier (ACTIVE / ABANDONED / CONVERTED), lignes de panier (produit, quantité, prix unitaire à l'ajout)
Tables	`Cart`, `CartItem`
Finalité	Permettre au client de préparer sa commande de manière persistante entre plusieurs sessions. Le panier persist côté serveur pour éviter la perte de sélection.
Base légale	**Art. 6.1.b — Exécution du contrat** : la persistance du panier est une fonctionnalité clé du service drive.
Justification	Le stockage côté serveur du panier (vs. localStorage) est justifié par la nécessité de permettre l'accès multi-appareils et d'éviter la perte de données lors de la fermeture du navigateur.
Durée de conservation	Durée du compte actif. Suppression physique à la suppression de compte (Art. 17). Les paniers ABANDONED peuvent être purgés après 30 jours d'inactivité (recommandation).
Acteurs ayant accès	CLIENT (son propre panier) / ADMIN (paniers abandonnés — analyse opérationnelle)
Transfert hors UE	Non
Mesures de sécurité	Guard IDOR : vérification `cart.clientId === req.user.id` à chaque accès.

T05 — PROGRAMME DE FIDÉLITÉ

CHAMP	VALEUR
Données traitées	`client_id` (FK), `loyalty_points` (entier), `loyalty_status` (booléen)
Tables	`Client_History`
Finalité	Comptabiliser les points accumulés par le client dans le cadre du programme de fidélité. Activer/désactiver l'accès aux avantages associés.
Base légale	**Art. 6.1.f — Intérêt légitime** : le programme de fidélité bénéficie au client (avantages) et à l'entreprise (engagement). Il ne constitue pas un profilage comportemental — seul le nombre de points est stocké, sans analyse des habitudes d'achat.
Justification	Pas de profilage comportemental : le score de fidélité est un compteur simple, non couplé à des données démographiques ou de navigation. L'intérêt légitime est proportionné et non contraire aux droits de la personne.
Durée de conservation	Durée du compte actif. Suppression physique à la suppression de compte.
Acteurs ayant accès	CLIENT (ses propres points) / ADMIN (tous les comptes fidélité)
Transfert hors UE	Non

T06 — NOTIFICATIONS TRANSACTIONNELLES

CHAMP	VALEUR
Données traitées	`client_id` (FK), `order_id` (FK nullable), type de notification (CONFIRMATION / READY / CANCELLATION / SUBSTITUTION), canal (EMAIL / SMS / PUSH), statut d'envoi, horodatage d'envoi
Tables	`Notification`
Finalité	Informer le client des étapes clés de sa commande (confirmation, commande prête, annulation, substitution proposée). Conserver la preuve d'envoi en cas de litige.
Base légale	**Art. 6.1.b — Exécution du contrat** : les notifications transactionnelles (confirmation, retrait, substitution) sont inhérentes à l'exécution du service drive. Elles ne requièrent pas de consentement séparé au titre de la directive ePrivacy.
Durée de conservation	Durée du compte actif. Suppression physique à la suppression de compte. Conservation recommandée 1 an pour preuve en cas de litige.
Acteurs ayant accès	CLIENT (ses propres notifications) / ADMIN (déclenchement manuel, supervision)
Provider retenu	**Brevo** (email + SMS) — Sendinblue SAS, France. Serveurs AWS Irlande (EEE) + infra France.
Transfert hors UE	**Aucun** — Brevo héberge les données dans l'EEE.
Action requise	**Signer le DPA Brevo** depuis l'interface du compte avant mise en production. Séparer transactionnel et promotionnel dans la configuration Brevo.

T07 — GESTION DU CONSENTEMENT COOKIES

CHAMP	VALEUR
Données traitées	`client_id` (FK), `cookie_analytics` (booléen), `cookie_loyalty` (booléen), `consented_at`, `withdrawn_at` (nullable), `ip_address`, `user_agent`, `version` de la politique cookies
Tables	`Consent`
Finalité	Enregistrer et prouver le consentement (ou son retrait) de chaque utilisateur concernant les cookies non strictement nécessaires. Permettre la re-sollicitation en cas d'évolution de la politique cookies (`version`).
Base légale	**Art. 6.1.f — Intérêt légitime** : conserver la preuve du consentement constitue un intérêt légitime du responsable de traitement pour démontrer sa conformité en cas de contrôle CNIL (principe d'accountability, Art. 5.2 RGPD). La base légale est identique à celle retenue dans la politique d'effacement — cohérence obligatoire entre les deux documents (EDPB 2/2019).
Durée de conservation	**Durée indéterminée** — preuve légale de conformité. Pseudonymisation du `client_id` à la suppression de compte. `ip_address` dans Consent = donnée personnelle → 1 an (Art. L34-1).
Acteurs ayant accès	CLIENT (ses propres consentements) / ADMIN (supervision conformité)
Transfert hors UE	Non — Supabase Frankfurt
Mesures de sécurité	Bandeau : Vanilla CookieConsent. Aucune case pré-cochée. Bouton "Refuser tout" aussi visible que "Accepter tout". Cookies strictement nécessaires (JWT) exemptés de consentement.

T08 — JOURNALISATION DES ACTIONS SYSTÈME (AUDITLOG)

CHAMP	VALEUR
Données traitées	`actor_id` (id utilisateur), `actor_role`, action réalisée, table concernée, id de l'enregistrement, adresse IP, horodatage
Tables	`AuditLog`
Finalité	Tracer les actions sensibles (connexion, modification de statut commande, exercice de droits RGPD, tentatives d'accès non autorisées) pour permettre la détection d'anomalies et démontrer la conformité en cas de contrôle CNIL.
Base légale	**Art. 6.1.f — Intérêt légitime** : la journalisation est une mesure de sécurité obligatoire (Art. 32 RGPD). L'intérêt légitime de l'organisation à détecter les fraudes et à prouver sa conformité est proportionné à l'impact sur la vie privée (les logs sont limités aux actions système, pas au contenu des données).
Durée de conservation	**1 an** (Art. L34-1). Purge automatique recommandée : cron job mensuel ou TTL en base.
Acteurs ayant accès	ADMIN uniquement
Transfert hors UE	Non
Mesures de sécurité	`actor_id` pseudonymisé (HMAC-SHA256) à la suppression du compte concerné. Jamais de mot de passe ni de donnée de carte en clair dans les logs. AuditLog en append-only — aucune route DELETE exposée.
Actions tracées	`LOGIN_SUCCESS`, `LOGIN_FAILED`, `ORDER_CREATED`, `STATUS_UPDATED`, `DELETION_REQUESTED`, `DELETION_COMPLETED`, `DELETION_FAILED`, `EXPORT_REQUESTED`, `ROLE_CHANGED`

T09 — GESTION DES EMPLOYÉS — PRÉPARATEURS

CHAMP	VALEUR
Données traitées	Prénom, initiales du nom, email professionnel, mot de passe (Bcrypt), téléphone professionnel, rattachement magasin (`store_id`)
Tables	`Preparer`
Finalité	Créer et gérer l'accès des préparateurs à l'interface de gestion des commandes. Permettre l'authentification et la contrainte `storeId` .
Base légale	**Art. 6.1.b — Exécution du contrat de travail** : la création du compte préparateur est une condition nécessaire à l'exercice des fonctions.
Durée de conservation	Durée du contrat. **5 ans après la fin du contrat** (Art. L3243-4 Code du travail + Référentiel CNIL RH 2026).
Acteurs ayant accès	OPERATOR (ses propres données) / MANAGER (données préparateurs de son magasin) / ADMIN (toutes). Note : la hiérarchie d'accès est asymétrique — les Managers voient les données des Préparateurs, mais pas l'inverse, justifiant des fiches distinctes (T09/T10).
Transfert hors UE	Non
Mesures de sécurité	MFA obligatoire. Mot de passe Bcrypt. Contrainte `storeId` : l'OPERATOR ne peut accéder qu'aux ressources de son magasin.

T10 — GESTION DES MANAGERS

CHAMP	VALEUR
Données traitées	Prénom, initiales du nom, email professionnel, mot de passe (Bcrypt), téléphone professionnel, rattachement magasin (`store_id`)
Tables	`Manager`
Finalité	Créer et gérer l'accès des managers à l'interface de supervision (plannings, performances, stock, créneaux).
Base légale	**Art. 6.1.b — Exécution du contrat de travail**
Durée de conservation	Durée du contrat. **5 ans après la fin du contrat** (Art. L3243-4 Code du travail).
Acteurs ayant accès	MANAGER (ses propres données) / ADMIN (toutes). Fiche distincte de T09 — les droits d'accès entre rôles sont asymétriques.
Transfert hors UE	Non
Mesures de sécurité	MFA obligatoire.

T11 — GESTION DES PLANNINGS (SCHEDULE)

CHAMP	VALEUR
Données traitées	`preparer_id` (FK), `store_id`, date, heure de début, heure de fin, statut (PRESENT / ABSENT / ON_LEAVE), commentaire optionnel
Tables	`Schedule`
Finalité	Permettre au Manager de connaître les disponibilités de son équipe afin d'estimer la capacité de préparation et d'organiser les créneaux clients.
Base légale	**Art. 6.1.b — Exécution du contrat de travail** : la gestion du planning est une obligation inhérente à la relation employeur-employé.
Durée de conservation	**5 ans après la fin du contrat** du préparateur (Art. L3243-4 Code du travail + Référentiel CNIL RH).
Acteurs ayant accès	OPERATOR (son propre planning — lecture seule) / MANAGER (planning de son équipe) / ADMIN (tous)
Transfert hors UE	Non

T12 — SUIVI DES PERFORMANCES DES PRÉPARATEURS

CHAMP	VALEUR
Données traitées	`preparer_id` (FK), nombre de commandes préparées, temps moyen de préparation, taux d'erreur, signalements de ruptures de stock, score synthétique global (`global_score`), période (dates début/fin)
Tables	`Performance`
Finalité	Permettre au Manager d'évaluer la performance individuelle des préparateurs pour des objectifs d'amélioration opérationnelle. Générer un score synthétique consultable rapidement.
Base légale	**Art. 6.1.f — Intérêt légitime de l'employeur**, confirmé par le test en trois étapes (LIA) : (1) intérêt légitime réel — optimisation opérationnelle et gestion RH documentée ; (2) nécessité — le `global_score` agrège des indicateurs que le Manager ne pourrait pas suivre manuellement à l'échelle de l'équipe ; (3) mise en balance — le traitement est borné au contexte professionnel, l'accès est restreint, aucune décision automatique n'en découle, et le préparateur dispose d'un droit d'opposition Art. 21 documenté. La mise en balance est favorable à l'employeur.
Justification	Le score synthétique (`global_score`) est calculé automatiquement mais n'aboutit à aucune décision automatisée (pas de licenciement automatique, pas de sanction sans intervention humaine). L'accès est strictement limité aux rôles Manager et Admin. Un LIA (Legitimate Interest Assessment) a été conduit et documenté dans la présente entrée.
Obligations employeur	Conformément à l'Art. L1222-4 du Code du travail, les préparateurs doivent être informés de l'existence de ce dispositif de suivi de performance préalablement à sa mise en œuvre. En contexte réel, une consultation du CSE (Comité Social et Économique) serait requise avant déploiement (Art. L2312-38 Code du travail). Ces obligations sont hors périmètre du prototype scolaire mais devront être satisfaites avant tout déploiement en production.
Droit d'opposition	Un préparateur peut s'opposer à ce traitement (Art. 21 RGPD). Procédure documentée : suspension du traitement associé à l'identifiant concerné et notification au responsable opérationnel. Réponse sous 1 mois (Art. 12 RGPD).
Durée de conservation	**5 ans après la fin du contrat** du préparateur (Référentiel CNIL RH 2026).
Acteurs ayant accès	MANAGER (son équipe uniquement) / ADMIN (tous) — OPERATOR n'a accès qu'à ses propres scores
Transfert hors UE	Non
Risque identifié	Donnée RH sensible relevant du traitement T12 — évaluation automatisée individuelle (critère DPIA rempli). Aucune décision automatique à effet juridique — DPIA conduite, risques résiduels acceptables.

T13 — LOGS SERVEUR NGINX

CHAMP	VALEUR
Données traitées	Adresse IP, User-Agent, URL appelée, code HTTP de réponse, horodatage
Tables	Fichiers de logs système (hors base de données)
Finalité	Assurer la sécurité du serveur, détecter les tentatives d'intrusion et les comportements anormaux (DDoS, crawling, etc.).
Base légale	**Art. 6.1.f — Intérêt légitime** : la journalisation réseau est une mesure de sécurité standard. L'IP est une donnée personnelle qualifiée selon la jurisprudence CJUE (C-582/14 Breyer).
Durée de conservation	**1 an** — Art. L34-1 (obligation de conservation des données de connexion).
Acteurs ayant accès	Équipe infrastructure (ADMIN système)
Transfert hors UE	Non — hébergement local / Docker
Mesures de sécurité	Séparation de la configuration de cache entre ressources statiques et routes API authentifiées. Les endpoints protégés par authentification sont exclus de toute mise en cache (`proxy_no_cache 1`). En-tête `Cache-Control: private, no-store` appliqué sur l'ensemble des routes authentifiées.

T14 — SUBSTITUTIONS DE PRODUITS

CHAMP	VALEUR
Données traitées	`order_item_id` (FK), produit commandé (`original_product_id`), produit de remplacement proposé (`proposed_product_id`), statut (PENDING / ACCEPTED / REFUSED), horodatage
Tables	`SubstitutionProposal`
Finalité	Permettre au préparateur de signaler une rupture de stock et de proposer un produit alternatif. Permettre au client d'accepter ou refuser la substitution.
Base légale	**Art. 6.1.b — Exécution du contrat** : la gestion des substitutions est inhérente au service drive (rupture de stock inévitable).
Durée de conservation	Active : durée de la commande. Après effacement : pseudonymisation via `order_item_id → order_id → client_id` — conservation 10 ans (obligation comptable, même base que T03).
Acteurs ayant accès	CLIENT (ses propres substitutions) / OPERATOR, MANAGER (magasin concerné) / ADMIN (toutes)
Transfert hors UE	Non

T15 — GESTION DES CRÉNEAUX DE RETRAIT

CHAMP	VALEUR
Données traitées	`store_id`, date, heure de début/fin, capacité max, nombre de commandes actuelles, disponibilité
Tables	`PickupSlot`
Finalité	Proposer au client des créneaux disponibles pour le retrait de sa commande. Organiser la capacité de préparation du magasin.
Base légale	**Art. 6.1.b — Exécution du contrat**
Note RGPD	Les données du créneau en elles-mêmes ne sont pas personnelles. Le lien créneau-commande-client dans la table `Order` est le vecteur personnel — couvert par T03.
Durée de conservation	Durée opérationnelle + 10 ans via la table `Order` (obligation comptable).
Acteurs ayant accès	CLIENT (créneaux disponibles — lecture) / MANAGER (gestion de son magasin) / ADMIN (tous)
Transfert hors UE	Non

SYNTHÈSE DES BASES LÉGALES

BASE LÉGALE	TRAITEMENTS CONCERNÉS
Art. 6.1.b — Exécution du contrat	T01, T02, T03, T04, T06, T09, T10, T11, T14, T15
Art. 6.1.c — Obligation légale	T03 (conservation comptable 10 ans — Art. L123-22)
Art. 6.1.f — Intérêt légitime	T05, T07, T08, T12, T13

SYNTHÈSE DES DURÉES DE CONSERVATION

DONNÉE	CONSERVATION ACTIVE	ARCHIVE OBLIGATOIRE	DURÉE ARCHIVE
Profil client (Client, Client_Account)	Durée du compte actif	—	—
Compte inactif	—	2 ans → notification → purge	—
Historique commandes (Order, OrderItem, Payment)	Durée du compte actif	Pseudonymisé après effacement	**10 ans** (Art. L123-22)
Panier et lignes (Cart, CartItem)	Durée du compte actif	—	—
Fidélité (Client_History)	Durée du compte actif	—	—
Notifications	Durée du compte actif	—	—
Consentements (Consent)	Durée indéterminée	Jamais supprimé — pseudonymisé	Durée indéterminée
Données Préparateur (Preparer)	Durée du contrat		**5 ans** après départ
Données Manager	Durée du contrat		**5 ans** après départ
Planning (Schedule)	Durée du contrat		**5 ans** après départ
Performance	Durée du contrat		**5 ans** après départ
AuditLog	—	**1 an** (Art. L34-1)	
Logs Nginx	—	**1 an** (Art. L34-1)	
JWT access token	15 min (CLIENT/OPERATOR), 10 min (ADMIN)	—	—
JWT refresh token	7j (CLIENT), 8h (OPERATOR/MGR), 4h (ADMIN)	—	—